

结果被保存下来或者使字段、记录、表和数据库中数据失效的任何错误。例如，可能漏掉了表中的记录，或者没有正确更新而导致数据过期等。而输出错误主要是由在数据提取和操作数据指令过程中发生的错误引起的。针对这两种情况，可分别进行测试。

对数据库功能的测试可以依赖工具进行，常用的数据库测试工具有 DBunit、QTP、DataFactory、Crash-me（MySQL 自带的测试数据库性能的工具）等。

16.5.4 Web应用性能测试

由于 Web 应用无法确定客户端用户对 Web 应用的访问情况，用户数目会处于不断变化之中，而 Web 服务器的承载能力有限，并发数据量过大甚至超过服务器的承载能力，会导致 Web 应用阻塞甚至崩溃。

1. 性能测试内容

遇到关于性能测试的相关问题时，主要考虑的 Web 应用性能测试可以划分为速度测试、负载测试、压力测试、强度测试、并发测试、大数据量测试、配置测试和可靠性测试等。

1) 速度测试

速度测试包括网络连接速度测试和业务处理速度测试。

用户连接到 Web 应用的速度根据上网方式和带宽的变化而变化。当下载一个程序时，用户可能需要等待比较长的时间，但如果只是访问一个页面，Web 应用响应时间太长（如超过 3s），就可能导致用户没有耐心等待而离开，所以要对 Web 应用进行连接速度测试。

业务处理速度测试目前主要是针对关键业务进行手工测速，可以在多次测试的基础上求平均值，可以与测试工具测得的响应时间等指标作对比分析。

2) 负载测试

负载测试主要是确定在用户可接受的响应时间内，系统能够承担的并发用户的数量。由于成千上万的用户可能在同一时刻访问同一个 Web 应用，为了保证系统的正常运行，必须测试在最重的工作负载下 Web 应用的运行情况。负载级别可以是某个时刻同时访问 Web 应用的用户数量，也可以是在线数据处理的数量。例如，Web 应用能允许多少个用户同时在线，如果超过了这个数量，Web 应用是否能承受，会出现什么现象，Web 应用能否处理大量用户对同一个页面的请求等。

可以通过脚本来生成成千上万的“虚拟用户”同时访问 Web 应用并与 Web 应用进行交互。这些虚拟用户执行各种典型任务，如浏览 Web 页面、购买商品、提交数据、搜索数据库等。在虚拟用户执行这些任务的同时，记录下服务器的响应时间。当测试执行完成以后，分析通过负载测试得到的数据，如在不同交互情况下的 Web 页面传送所需时间、Web 页面传送出错信息等，经过一定的分析、计算、处理，得出 Web 应用能同时支持的用户数目、交互数目等，并尽可能找出多用户并发访问的瓶颈，最后以报告和图表的形式显示测试情况下 Web 应用的执行情况以及潜在问题存在的方

多用户访问的瓶颈可能发生在 Web 服务器、Web 应用服务器或（和）数据库服务器上，要明确确定瓶颈所在并非易事。另外，要确定同时访问 Web 应用的用户数目并不容易。可以参考

系统给出的参数结合实际情况进行估计，也可以选择有代表性的分布算法（如指数分布、常量分布、泊松分布等算法）来估计。

图 16-8 显示了经统计而得到的 Web 应用负载、Web 应用响应时间与用户可能放弃的比例之间的关系。从图中可以看出，并发用户数目越多，Web 应用的响应时间越长，从而用户放弃执行该动作的可能性越大。因此，必须从 Web 应用的实际负载能力出发，确定合适的并发用户数目，以先保证服务质量，然后在系统性能稳定的范围内，再考虑为更多的用户提供优质服务。

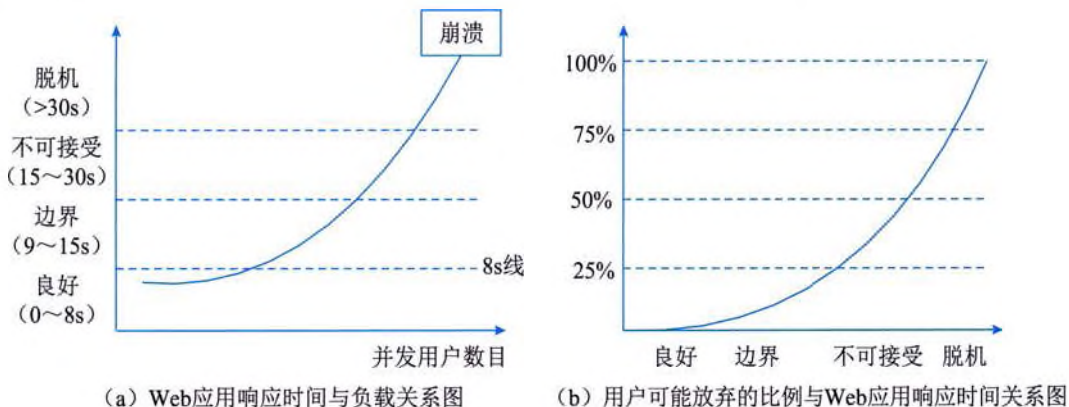


图 16-8 多用户性能测试中部分数据关系图

负载测试应该安排在 Web 应用部署以后，在实际的网络环境中进行测试。因为一个企业内部员工，特别是项目组人员总是有限的，而一个 Web 应用能同时处理的请求数量将远远超出这个限度。所以，只有部署之后，接受负载测试，其结果才是正确可信的。

3) 压力测试

压力测试是负载测试的延续，通过对 Web 应用不断加压，来发现其在什么条件下变得不可承受，查出 Web 应用对异常情况的抵抗能力，找出性能瓶颈，从而获得系统能提供的最大服务级别的测试。压力测试关注 Web 应用在大量并发用户、传送大量数据和大业务量的情况下的性能变化，关注 Web 应用能否长时间运行，响应是否太慢、系统是否崩溃、能否恢复等。

在很多情况下，可能会有黑客或不法分子试图通过发送大量数据包来攻击服务器。出于安全的原因，测试人员应该知道当系统过载时，需要采取哪些措施，而不是简单地提升系统性能。

压力测试的主要手段是通过产生模拟业务对被测试系统进行加压，具体如下：

- (1) 当正常的用户点击率为“100/s”时，运行点击率为“500/s”的测试用例。
- (2) 定量地增长数据输入率，检测对数据处理的反应能力。
- (3) 运行需要最大存储空间（或其他资源）的测试用例。
- (4) 运行可能导致操作系统崩溃或此版数据剧烈抖动的测试用例。

一个好的压力测试必须能够提供产生压力的手段、能够对后台系统进行监控、能够对压力数据进行分析，并快速找出被测系统的瓶颈。当前流行的压力测试工具有 LoadRunner、WAS 和 WebLoad 等。

4) 强度测试

强度测试主要用于检查程序对异常情况的抵抗能力，检查系统在极限状态下运行时性能下降的幅度是否在允许的范围内。强度测试可以测试系统在超负荷情况下的表现，也可以测试系统在最差工作环境下的工作能力，或者验证系统在标准工作压力下的各种资源的最下限指标。

5) 并发测试

并发测试主要是指当测试多个用户同时访问同一个 Web 应用、同一个模块数据记录时是否存在线程同步问题、死锁或其他性能问题。其目的主要体现在：以真实的业务为依据，选择有代表性的、关键的业务操作设计测试案例，以评价系统的当前并发能力。

在实际测试工作中一般都借助工具来模拟并发访问，如 LoadRunner。

6) 大数据量测试

大数据量测试主要测试运行数据量较大时或历史数据量较大时的性能情况，一般针对某些特殊的核心业务或一些日常比较常见的综合业务的测试。大数据量测试通常分为两种：①对某些存储、传输和统计查询等业务进行大数据量的测试；②与并发测试相结合的极限状态下的总和测试。主要测试运行数据量较大或历史数据量较大时 Web 应用的性能情况。

由于大数据量测试一般在投产环境下进行，因此把它独立出来和疲劳强度测试一起进行，一般在测试后期进行。

大数据量测试分实时大数据量测试和极限状态下的测试。实时大数据量测试模拟用户工作时的实时大数据量，主要目的是测试用户较多或某些业务产生大数据量时系统是否稳定；极限状态下的测试是指被测 Web 应用使用了一段时间后，数据已经积累到了一定程度时，再查看系统是否正常。

7) 配置测试

配置测试指通过测试找到系统各项资源的最优分配原则，为系统调优提供依据。配置的可变性和不稳定性是 Web 工程面临挑战的重要因素。硬件、操作系统、浏览器、存储容量、网络通信速度和多种其他客户端因素对每个用户都是难以预测的。另外，某个用户的配置可能会有规律的改变（如操作系统升级、新的 ISP 和连接速度等），可能会导致客户端环境容易出错，这些错误既微妙又重要。如果两个用户不是在相同的客户端配置工作，一个用户对 Web 应用的印象以及 Web 应用的交互方式可能与另一个用户的体验有很大不同。

配置测试不是检查每种可能的客户端配置，而是测试一组可能的客户端和服务器端配置，以确保用户在所有配置中的体验是一样的，并且将特定于特殊配置的错误分离出来。例如，可以通过不停地调整 Oracle 的内存参数来进行测试，使之达到较好的性能。配置测试本质上是和其他性能测试一起进行的。

8) 可靠性测试

软件可靠性是指在规定条件下，在规定时间内，软件无失效工作的概率。该概率受输入和使用以及其存在故障的影响，系统输入将确定是否会遇到存在的故障。而可靠性测试是指给系统增加一定业务压力的情况下，让系统运行一段时间，以此来检测系统是否稳定。

Web 应用的可靠性测试的目的如下：

(1) 通过在有使用代表性的环境中执行 Web 应用，以证实 Web 应用需求是否正确实现。

(2) 数据的准确性关系到 Web 应用可靠性评估的准确度，通过数据采集、模型选择、模型拟合以及系统可靠性评估四个步骤，为进行 Web 应用可靠性估计采集准确的数据。

(3) 找出所有对 Web 应用可靠性影响较大的错误。

2. 性能测试方法

Web 应用的性能测试需要有良好的测试方法来保证。执行 Web 应用性能测试的方法有许多，它们各有优势，其中具有代表性的主要方法有虚拟用户方法和 WUS（Website Usage Signature，站点使用签名）方法。

1) 虚拟用户方法

虚拟用户方法通过模拟真实用户的行为来对待测 Web 应用施加预期工作负载，以测量待测系统的性能，如事务的响应时间、服务器的吞吐量等。它以真实用户平时生产环境下的“事务处理”（用户为完成一个商业业务而执行的一系列操作）作为负载的基本组成单位，用“虚拟用户”（模拟用户行为的测试脚本）来模拟真实用户。工作负载的信息（如并发虚拟用户数、商务处理的执行频率等）通过人工收集和分析系统的特征来获得。

支持该方法的性能测试工具可用较少的硬件资源模拟出成百上千虚拟用户同时访问，并可模拟来自不同的地址、不同浏览器类型以及不同网络连接方式的请求，同时可实时监控相关性能指标，帮助测试人员分析测试结果。该方法易于实现和便于操作，已经为绝大多数主流的 Web 应用性能测试工具所采用，在实践中被证明是相当有效的。

这种方法需要测试人员有相当高的专业技能，需要根据预期工作负载设计准确的测试场景，以较好地模拟工作负载进行测试。

2) WUS 方法

基于 WUS 的概念来设计测试场景，强调建立真实的负载。WUS 是为了衡量测试负载和真实负载之间的接近程度，是一系列能全面刻画负载的参数和测量指标的集合，包括每小时浏览的页面、平均访问持续时间、每次访问平均浏览的页面以及页面请求分布等。这些参数可以从日志文件中得到，即需要 Web 应用的运行日志，也就是说 Web 应用正常运作一段时间后才能进行测试。参数同时也包括一些影响负载的客户端变量，如用户对站点的熟悉程度、对延迟的忍耐程度和客户端连接速度等。

此外，采用类似的 Web 应用的日志信息来模拟待测的 Web 应用工作负载方法，理论上也是可行的，只不过这个条件在现实测试环境中非常苛刻，基本上难以实现。

16.5.5 Web应用安全性测试

Web 应用运行在 Internet 上，其安全性一直广受关注，Web 应用安全性测试则是一个复杂的主题。Web 应用安全性测试是对整个 Web 应用的安全防卫措施的有效性进行测试，以揭露安全机制中的漏洞。通常的安全机制包括信息访问控制、用户身份校验以及对机密信息进行加密等，同时要能根据用户的访问情况判断出该用户是正常的用户还是蓄意的破坏者。

Web 应用的安全性测试主要包括数据加密测试、用户身份验证测试、日志文件测试、脚本

测试、Session 测试、备份与恢复测试等内容，遇到相关问题时可以根据本节所述方法进行实际操作。

1. 数据加密测试

数据加密测试是测试 Web 应用使用的关键数据是否经过了加密，所选择的加密算法是否合适等内容。

2. 用户身份验证测试

Web 应用中，用户身份验证直接关系到用户权利、隐私的安全，用户身份验证测试主要检查无效的用户名和密码能否登录，密码是否对大小写敏感，是否有验证次数的限制，是否存在不验证而直接进入 Web 应用的问题，是否存在不登录就可查看非会员页面和权限问题。

3. 日志文件测试

日志文件测试主要是检查 Web 运行的相关访问和状态信息是否写进了日志文件，是否可追踪等。此外，需测试 Web 应用执行过程中所产生的错误是否作为日志保留下来，供技术人员分析该错误是由系统实现漏洞引起的还是由于黑客攻击引起的。

日志文件测试的主要测试内容如下：

- (1) 日志是否记录所有的事务处理。
- (2) CPU 的占有率是否很高。
- (3) 是否有例外的进程占用。
- (4) 是否记录失败的注册企图。
- (5) 是否记录被盗信用卡的使用。
- (6) 是否在每次事务完成的时候都进行保存。
- (7) 是否记录 IP 地址。
- (8) 是否记录用户名等。

4. Session 测试

Session 测试主要检查 Web 应用是否有超时的限制，也就是检查用户登录 Web 应用后在一定时间内没有点击任何页面，是否需要重新登录才能正常使用，检查超时后能否自动退出，退出之后，浏览器回退按钮是否可以回到登录页面等。

5. 备份与恢复测试

根据 Web 应用对安全性的要求可以采用多种备份与恢复手段，如数据库增量备份、数据库完全备份、数据库差量备份和系统完全备份等。出于更高的安全性要求，某些实时系统经常会采用双机热备或多机热备。除了对这些备份与恢复方式进行验证测试以外，还要评估这种备份与恢复方式是否满足 Web 应用的安全性需求。

6. 访问控制策略测试

访问控制策略测试主要检查管理接口是否只有授权的管理员才允许进行访问，是否有完善的访问控制策略文档，文档中是否精确定义了每类用户可以访问的功能和内容，执行访问控制